8.1

```
PS C:\Users\tomas\Desktop\TM-99080\Artefakt08> python .\81_manifest_scanner.py
>>> URUCHAMIANIE AUDYTU: ../Artefakt02/decompiled_apk/AndroidManifest.xml <<<
[SUCCESS] Wygenerowano czytelny raport: RiskyPermission.xml
[INFO] Znaleziono 5 podejrzanych uprawnień.
[⚠ ALERT] Wykryto aktywną flagę DEBUGGABLE!
```

RiskyPermission.xml

```xml
<?xml version="1.0" ?>
<SecurityAudit app="ApiDemos_Security_Check" status="ReviewRequired">
  <Flags>
    <Debuggable>true</Debuggable>
  </Flags>
  <RiskyPermissions>
    <Permission>android.permission.READ_CONTACTS</Permission>
    <Permission>android.permission.INTERNET</Permission>
    <Permission>android.permission.WRITE_EXTERNAL_STORAGE</Permission>
    <Permission>android.permission.RECORD_AUDIO</Permission>
    <Permission>android.permission.CAMERA</Permission>
  </RiskyPermissions>
</SecurityAudit>
```

Preview 81_permissions_report.md

🛡️ AUDYT BEZPIECZEŃSTWA: MANIFEST SCANNER

Status: Wykonano automatyczną ekstrakcję ryzyka.

📝 1. Zawartość RiskyPermission.xml

Zidentyfikowano następujące wpisy krytyczne:

- **Debuggable:** `true` (⚠️ WYSOKIE RYZYKO - Aplikacja podatna na inżynierię wsteczną w czasie rzeczywistym).
- **Permissions:** Wykryto uprawnienia dające dostęp do sieci (`INTERNET`) oraz pamięci zewnętrznej.

🧠 2. Interpretacja Inżynierska

Z punktu widzenia bezpieczeństwa, najpoważniejszym problemem jest flaga `debuggable`. Pozwala ona na użycie komendy `adb jdwp` do śledzenia procesów aplikacji przez osoby niepowołane.

🛠️ 3. Akcja korygująca

Zaleca się wdrożenie skryptu do procesu CI/CD (np. w Jenkins/GitHub Actions), który będzie automatycznie blokował buildy, jeśli `RiskyPermission.xml` wykaże flagę `debuggable="true"`.

Raport wykonanay przez:

Podpis: Tomasz, 99080 **Data:** 30.03.2026

8.2

```
PS C:\Users\tomas\Desktop\TM-99080\Artefakt08> python .\82_secrets_finder.py
>>> SKANOWANIE ZASOBÓW: ../Artefakt02/decompiled_apk/res/values/strings.xml <<<
[INFO] Analiza zakończona. Znaleziono 590 potencjalnych punktów wycieku.
  [URL_Endpoint] -> http://www.example.com/lala/foobar@example.com
  [URL_Endpoint] -> https://www.google.com,
  [URL_Endpoint] -> http://www.google.com
  [Potential_Secret] -> password
  [Potential_Secret] -> Password
  [API_Key_Format] -> activity_styled_text
  [API_Key_Format] -> alert_dialog_progress_button
  [API_Key_Format] -> buttons_1_small_down
  [API_Key_Format] -> remote_service_connected
  [API_Key_Format] -> abc_searchview_description_search
  [API_Key_Format] -> activity_modern_animation_zoom
  [API_Key_Format] -> reorder_second_to_front
  [API_Key_Format] -> isolated_service_1_stopped
  [API_Key_Format] -> secure_view_step1_heading
  [API_Key_Format] -> admin_receiver_status_disable_warning
  [API_Key_Format] -> advanced_preferences
  [API_Key_Format] -> table_layout_7_import
  [API_Key_Format] -> abc_shareactionprovider_share_with
  [API_Key_Format] -> flag_activity_clear_task
  [API_Key_Format] -> wipe_warning_second_no
  [API_Key_Format] -> autocomplete_2_focus
  [API_Key_Format] -> presentation_with_media_router_now_playing_remotely
```

82_secrets_found.txt

```
1   === RAPORT ZNALEZIONYCH WRAŻLIWYCH DANYCH ===
2   [URL_Endpoint] -> http://www.example.com/lala/foobar@example.com
3   [URL_Endpoint] -> https://www.google.com,
4   [URL_Endpoint] -> http://www.google.com
5   [Potential_Secret] -> password
6   [Potential_Secret] -> Password
7   [API_Key_Format] -> activity_styled_text
8   [API_Key_Format] -> alert_dialog_progress_button
9   [API_Key_Format] -> buttons_1_small_down
10  [API_Key_Format] -> remote_service_connected
11  [API_Key_Format] -> abc_searchview_description_search
12  [API_Key_Format] -> activity_modern_animation_zoom
13  [API_Key_Format] -> reorder_second_to_front
14  [API_Key_Format] -> isolated_service_1_stopped
15  [API_Key_Format] -> secure_view_step1_heading
16  [API_Key_Format] -> admin_receiver_status_disable_warning
17  [API_Key_Format] -> advanced_preferences
18  [API_Key_Format] -> table_layout_7_import
19  [API_Key_Format] -> abc_shareactionprovider_share_with
20  [API_Key_Format] -> flag_activity_clear_task
21  [API_Key_Format] -> wipe_warning_second_no
22  [API_Key_Format] -> autocomplete_2_focus
23  [API_Key_Format] -> presentation_with_media_router_now_playing_remotely
24  [API_Key_Format] -> admin_receiver_status_pw_succeeded
25  [API_Key_Format] -> alert_dialog_two_buttons_old_school
26  [API_Key_Format] -> password_minimum_length
27  [API_Key_Format] -> secure_view_step3_detail
28  [API_Key_Format] -> cycle_custom_gravity
```

Preview 82_secrets_found.md

🛡️ RAPORT ANALIZY WYCIEKÓW (SECRETS)

Student: Tomasz Bednarz
Indeks: 99080 **Data raportu:** 30-03-2026

🔴 1. Trzy najbardziej groźne znaleziska (High Risk)

Poniższe elementy wymagają natychmiastowej zmiany w kodzie źródłowym:

1. **[URL_Endpoint] ->** `http://www.example.com/lala/foobar@example.com`
   - *Uzasadnienie:* Zawiera adres e-mail w ścieżce URL, co sugeruje wyciek danych użytkownika lub twardo zakodowane poświadczenia testowe.
2. **[Potential_Secret] ->** `password`
   - *Uzasadnienie:* Obecność tego słowa w `strings.xml` sugeruje, że deweloper mógł tam zapisać domyślne hasło do bazy lub usługi.
3. **[Potential_Secret] ->** `reset_password_warning`
   - *Uzasadnienie:* Może wskazywać na lokalne przechowywanie mechanizmów resetu hasła, które mogą zostać zmanipulowane.

🟢 2. Trzy znaleziska typu "False Positive" (Low/No Risk)

Poniższe elementy zostały błędnie sklasyfikowane jako zagrożenie:

1. **[URL_Endpoint] ->** `http://www.google.com`
   - *Uzasadnienie:* To standardowy adres URL wyszukiwarki, powszechnie używany do testowania łączności internetowej.
2. **[API_Key_Format] ->** `table_layout_1_triple_star`
   - *Uzasadnienie:* Mimo że pasuje do wzorca długiego ciągu, jest to po prostu nazwa identyfikatora elementu UI (Layoutu).
3. **[API_Key_Format] ->** `abc_font_family_display_3_material`
   - *Uzasadnienie:* Jest to nazwa zasobu systemowego związanego z czcionkami biblioteki Material Design.

🎓 Wnioski końcowe

Automatyczne skanowanie RegEx jest skuteczne, ale wymaga **manualnej weryfikacji inżyniera**, ponieważ skrypt nie rozumie kontekstu biznesowego aplikacji.

8.3

```
PS C:\Users\tomas\Desktop\TM-99080\Artefakt08> python .\83_library_audit.py
>>> ZADANIE 8.3: ANALIZA ŁAŃCUCHA DOSTAW (SCA - Software Composition Analysis) <<<
[INFO] Rozpoczynam skanowanie bibliotek z pliku: requirements.txt...

 Wynik audytu: Znaleziono 4 podatności.
------------------------------------------------------------
🔴 [HIGH] com.google.android.gms (10.0.1)
    Id: CVE-2021-4352 | Opis: Błąd weryfikacji certyfikatu

🟠 [MEDIUM] com.squareup.okhttp (2.7.5)
    Id: CVE-2016-2402 | Opis: Podatność na Man-in-the-Middle

🔴 [CRITICAL] org.apache.commons (1.0.0)
    Id: CVE-2015-7501 | Opis: Zdalne wykonanie kodu (RCE)

🟠 [LOW] com.android.support (25.0.0)
    Id: CVE-2019-1234 | Opis: Wyciek informacji w logach
```

8.4

```
PS C:\Users\tomas\Desktop\TM-99080\Artefakt08> python .\84_security_score.py
>>> ZADANIE 8.4: OBLICZANIE SECURITY SCORE (ALGORITHM V1) <<<

[📊] WYNIK KOŃCOWY: 0/100
[❌] STATUS: REJECTED (Aplikacja niebezpieczna)
```

8.5

Preview 85_final_audit.md

🏛️ RAPORT Z AUDYTU BEZPIECZEŃSTWA: APIDEMOS

Data: 30.03.2026 **Audytor:** Tomasz, 99080
Projekt: Mobilny System Demonstracyjny (Android)

📊 1. OCENA KOŃCOWA (SECURITY SCORE)

> **WYNIK:** 0/100
> **STATUS:** 🔴 REJECTED

🛡️ 2. KLUCZOWE OBSZARY RYZYKA

A. Konfiguracja Systemowa (Zadanie 8.1)

- **Problem:** Flaga `debuggable="true"` w Manifest.
- **Wpływ:** Umożliwia napastnikowi podpięcie debuggera i kradzież danych z pamięci ulotnej.

B. Wycieki Danych (Zadanie 8.2)

- **Problem:** Wykryto twardo zakodowane słowa kluczowe (np. `password`) w zasobach.
- **Wpływ:** Ryzyko przejęcia konta testowego lub dostępu do niepublicznych endpointów.

C. Biblioteki Zewnętrzne (Zadanie 8.3)

- **Problem:** Użycie `org.apache.commons` w wersji 1.0.0.
- **Wpływ:** Podatność **CVE-2015-7501 (CRITICAL)** pozwalająca na zdalne wykonanie kodu na urządzeniu użytkownika.

📝 3. MAPA DROGOWA NAPRAWCZA (REMEDIATION)

1. **[PRIORYTET 1]:** Aktualizacja biblioteki `org.apache.commons` do najnowszej bezpiecznej wersji.
2. **[PRIORYTET 1]:** Wyłączenie trybu debugowania w wersji produkcyjnej (Release build).
3. **[PRIORYTET 2]:** Przeniesienie wszystkich wrażliwych ciągów znaków ze `strings.xml` do bezpiecznego magazynu kluczy (Android Keystore).

🎓 WNIOSKI KOŃCOWE

Aplikacja w obecnym stanie **nie może zostać opublikowana**. Poziom ryzyka związanego z bibliotekami firm trzecich oraz błędną konfiguracją manifestu jest zbyt wysoki dla bezpiecznego użytkowania.